bot-finanzas

Bot de finanzas personales: slash commands de Discord, n8n y PostgreSQL

Repositorio: https://github.com/lyc4nthrope/bot-finanzas

Generado el 2026-10-16

bot-finanzas

Bot de finanzas personales: registra ingresos y gastos, y consulta saldos desde Discord.

Stack

Componente	Herramienta
Canal de chat	Slash commands de Discord
Automatización	n8n (Docker; primero local, luego Render)
Base de datos	PostgreSQL (contenedor local, luego Supabase)
IA opcional	Modelos gratuitos de OpenRouter

Configuración

1. Copia la plantilla de entorno y restringe sus permisos:

   ```
   cp .env.example .env && chmod 600 .env
   ```

2. Completa `.env`. Los valores marcados con `[SECRET]` no deben aparecer en chats ni en commits.

3. Inicia el stack local (Postgres, n8n y un túnel público temporal) y aplica las migraciones:

   ```
   docker compose --profile tunnel up -d
   for f in sql/0*.up.sql; do
     docker compose exec -T postgres sh -c 'psql -v ON_ERROR_STOP=1 -U "$POSTGRES_USER" -d
   "$POSTGRES_DB"' < "$f"
   done
   docker compose logs tunnel | grep -o 'https://.*trycloudflare.com'   # public URL
   ```

4. Activa los usuarios de mínimo privilegio y, en n8n (http://localhost:5678), crea la cuenta de propietario y una credencial de Postgres llamada `Postgres local` (host `postgres`, base de datos `finanzas`, usuario `bot_app`, contraseña `DB_BOT_PASSWORD` de `.env`):

   ```
   scripts/setup-database.sh local
   ```

5. Despliega el workflow y registra los slash commands:

   ```
   scripts/deploy-workflow.sh workflows/discord-interactions.json discord-interactions
   scripts/register-commands.sh
   ```

6. En el Discord Developer Portal, configura **Interactions Endpoint URL** como `<tunnel URL>/webhook/discord-interactions`.

Producción

```
Discord ──► Render (n8n, deploy/Dockerfile) ──► Supabase (PostgreSQL)
                ▲
     cron-job.org hace ping a /healthz cada 10 minutos para que la instancia gratuita no se suspenda
```

Componente	Ubicación	Notas
n8n	Servicio web gratuito de Render, Virginia	Se construye desde `deploy/Dockerfile`; los push no despliegan automáticamente
Estado de n8n	Supabase, esquema `n8n`	Rol `n8n_app`; la instancia de Render es desechable
Datos de dinero	Supabase, esquema `finance`	Rol `bot_app`: sin UPDATE, sin DDL
TLS hacia Supabase	`deploy/supabase-ca.crt`	Certificados verificados; nunca se desactiva la verificación

Configuración desde cero:

1. `scripts/setup-database.sh supabase --migrate` aplica las migraciones y habilita los roles.
2. `scripts/cloud-n8n.sh up`; luego abre http://localhost:5679 para crear la cuenta de propietario y una credencial de Postgres (`bot_app.<project-ref>`, SSL require) **antes** de que exista la instancia en la nube, para que su página de configuración nunca pueda ser reclamada públicamente.
3. `scripts/cloud-n8n.sh deploy workflows/discord-interactions.json <credential id> "<credential name>"`; luego `scripts/cloud-n8n.sh down`.
4. Crea el servicio en Render (Docker, `deploy/Dockerfile`, health check `/healthz`) con las variables indicadas en el ADR 0002, y apunta la Interactions Endpoint URL de Discord a `<render URL>/webhook/discord-interactions`.

Decisiones y mediciones: `docs/adr/0002-render-instead-of-hugging-face.md`.

Pruebas

Todas las pruebas se ejecutan contra el Postgres y el n8n locales reales; no se simula nada.

Script	Qué demuestra
`scripts/test-schema.sh`	Las restricciones de las tablas rechazan datos de dinero inválidos
`scripts/test-functions.sh`	Saldos, periodos (calendario de Bogotá), idempotencia, deshacer
`scripts/test-roles.sh`	Mínimo privilegio: qué pueden y qué no pueden hacer `bot_app` y `n8n_app`
`scripts/test-bot.sh`	El workflow de extremo a extremo: firmas, respuestas, escrituras en la base de datos

Documentación

- `docs/contract.md`: qué acepta y qué responde cada comando.

- `docs/workflow.md`: el workflow de n8n nodo por nodo, con capturas de pantalla.
- `docs/adr/`: decisiones de arquitectura y sus razones.
- `docs/bot-finanzas.pdf`: todo lo anterior en un solo PDF.

Los archivos Markdown son la fuente de verdad. Después de modificarlos o de modificar el workflow:

```
scripts/docs-screenshots.sh   # regenerates docs/images/ from a throwaway n8n
scripts/build-docs-pdf.sh     # regenerates docs/bot-finanzas.pdf
```

Estructura

```
discord/    definiciones de los slash commands
docs/       contrato y registros de decisiones de arquitectura (ADR)
sql/        migraciones de la base de datos
workflows/  workflows de n8n exportados (JSON, sin secretos)
scripts/    scripts de pruebas y utilidades
```

Contrato del bot (v1)

Qué acepta y qué devuelve el bot. El código debe seguir este archivo; primero se modifica este archivo.

Transporte

- Discord envía cada slash command como un `POST` HTTPS a `{WEBHOOK_URL}webhook/discord-interactions` ("Interactions Endpoint URL" de Discord).
- Toda solicitud incluye `X-Signature-Ed25519` y `X-Signature-Timestamp`. El bot verifica la firma sobre `timestamp + raw body` (los bytes exactos recibidos, nunca JSON re-serializado) con la clave pública de Discord.
  - Firma inválida o ausente → `401`, no se procesa nada.
  - Timestamp con más de 300 segundos de diferencia respecto del reloj del servidor → `401` (protección contra replay).
- `type: 1` (PING) → `{"type": 1}`.
- `type: 2` (APPLICATION_COMMAND) → `{"type": 4, "data": {"content": "...", "flags": 64}}`.
  - `flags: 64` hace que la respuesta solo sea visible para quien la envía (los datos financieros son privados).
- Los comandos básicos deben responder en menos de 3 segundos (límite de Discord).

Identidad

- Cada movimiento pertenece al id de usuario de Discord que envió el comando (`member.user.id` o `user.id`).
- Un usuario solo puede leer y modificar sus propios movimientos.

Montos

- Tipo de opción `INTEGER`, pesos colombianos enteros, `min_value: 1`, `max_value: 1000000000`.
- Por qué INTEGER y no NUMBER: en Colombia `20.000` significa veinte mil. Una opción NUMBER lo leería silenciosamente como `20`; una opción INTEGER hace que Discord lo rechace antes de enviarlo.
- Se muestra como `$20.000` (formato es-CO).

Comandos

Las definiciones de los slash commands están en `discord/commands.json`; sus opciones deben coincidir con las restricciones de la base de datos en `sql/001_transactions.up.sql`.

`/gasto`

Opción	Tipo	Obligatoria	Reglas
`monto`	INTEGER	sí	1 a 1,000,000,000

Opción	Tipo	Obligatoria	Reglas
`categoria`	STRING (choices)	sí	`mercado`, `comida`, `transporte`, `servicios`, `hogar`, `salud`, `deudas`, `otro`
`nota`	STRING	no	máximo 200 caracteres

Respuesta: `✅ Gasto registrado: $20.000 en mercado.\nGastado este mes: $350.000`

La misma interacción entregada dos veces se almacena una sola vez; la repetición recibe `Ese movimiento ya estaba registrado.` (también aplica a `/ingreso`).

`/ingreso`

Opción	Tipo	Obligatoria	Reglas
`monto`	INTEGER	sí	1 a 1,000,000,000
`categoria`	STRING (choices)	sí	`sueldo`, `ventas`, `regalo`, `otro`
`nota`	STRING	no	máximo 200 caracteres

Respuesta: `✅ Ingreso registrado: $1.500.000 (sueldo).\nSaldo total: $1.150.000`

`/saldo`

Sin opciones. Respuesta:

```
💰 Saldo total: $1.150.000
Este mes: ingresos $1.500.000 · gastos $350.000
```

`/resumen`

Opción	Tipo	Obligatoria	Reglas
`periodo`	STRING (choices)	no	`hoy`, `semana`, `mes` (predeterminado), `año`

Respuesta: totales de ingresos y gastos del periodo, más los gastos agrupados por categoría, de mayor a menor. Los periodos usan el calendario de `America/Bogota`; `semana` comienza el lunes.

`/deshacer`

Sin opciones. Elimina el movimiento más reciente de quien envía el comando y muestra lo que se eliminó: `↩️ Eliminado: gasto de $20.000 (mercado).\nSaldo total: $1.130.000` Si no hay nada que eliminar: `No hay movimientos para deshacer.` Los saldos negativos se muestran como `-$20.000`.

Errores

Caso	Respuesta
Comando desconocido	`No conozco ese comando.`
Base de datos no disponible	`⚠️ No pude guardar el movimiento. Intenta de nuevo en un momento.`
Cualquier otra falla	`⚠️ Algo salió mal. Intenta de nuevo.`

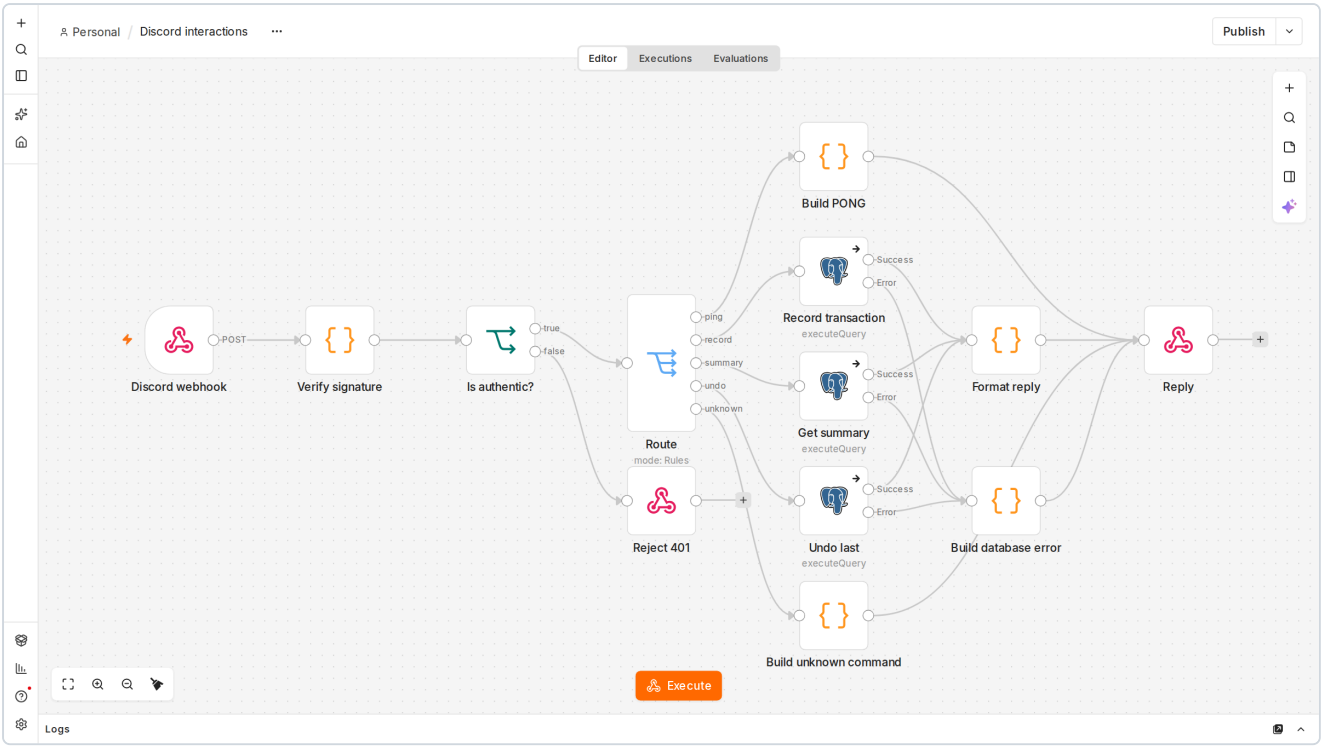
El bot nunca confirma un movimiento que no se haya almacenado.

Fuera del alcance de v1

- Registro en texto libre con IA (`/registrar` , fase 6).
- Edición de movimientos pasados (usa `/deshacer` y registra de nuevo).
- Presupuestos, alertas, notas de voz.

El workflow de n8n, nodo por nodo

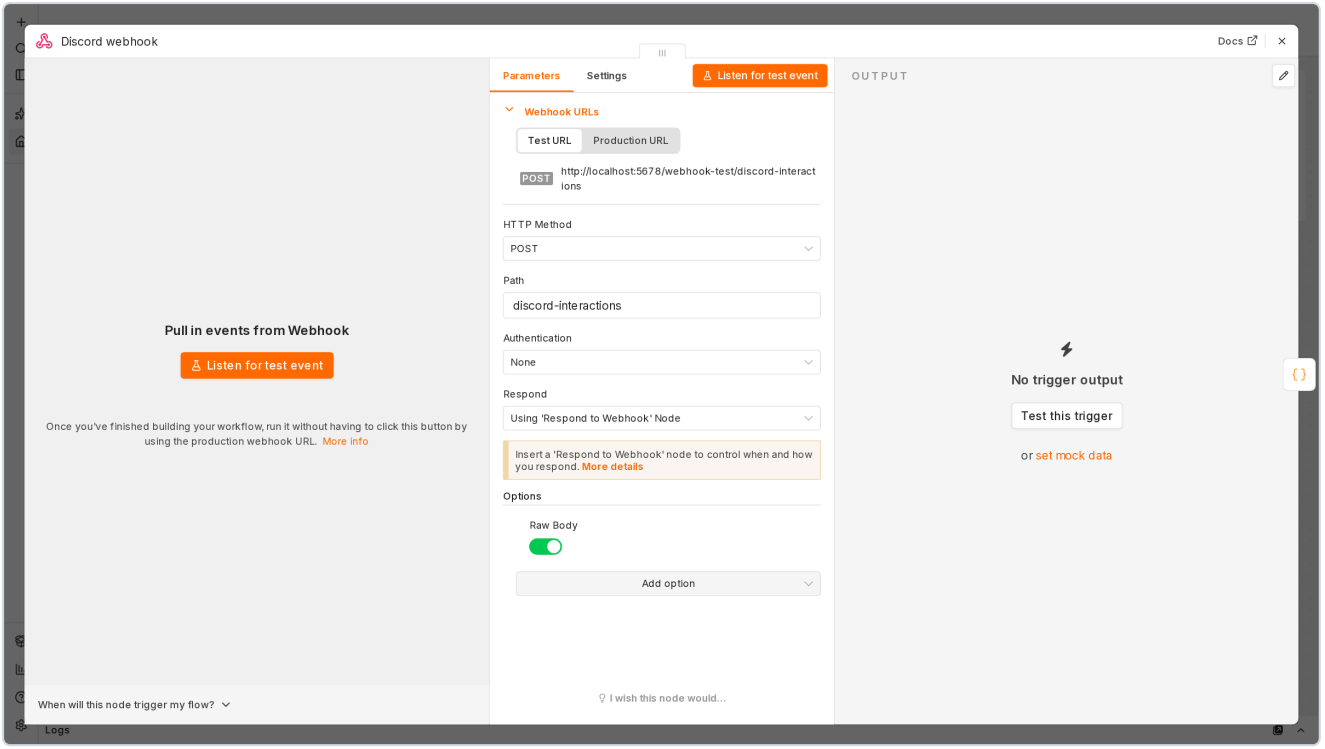
Archivo: `workflows/discord-interactions.json` (13 nodos). Las capturas de pantalla provienen de una instancia desechable de n8n que importó exactamente este archivo; la credencial de Postgres que se muestra es un marcador de posición.



El flujo: Discord envía cada slash command al webhook. El bot comprueba que la solicitud realmente proviene de Discord, la enruta según el comando, llama a una función SQL y responde en la misma respuesta HTTP. Las reglas de negocio residen en PostgreSQL (`sql/`); n8n solo adapta Discord a la base de datos.

1. Discord webhook

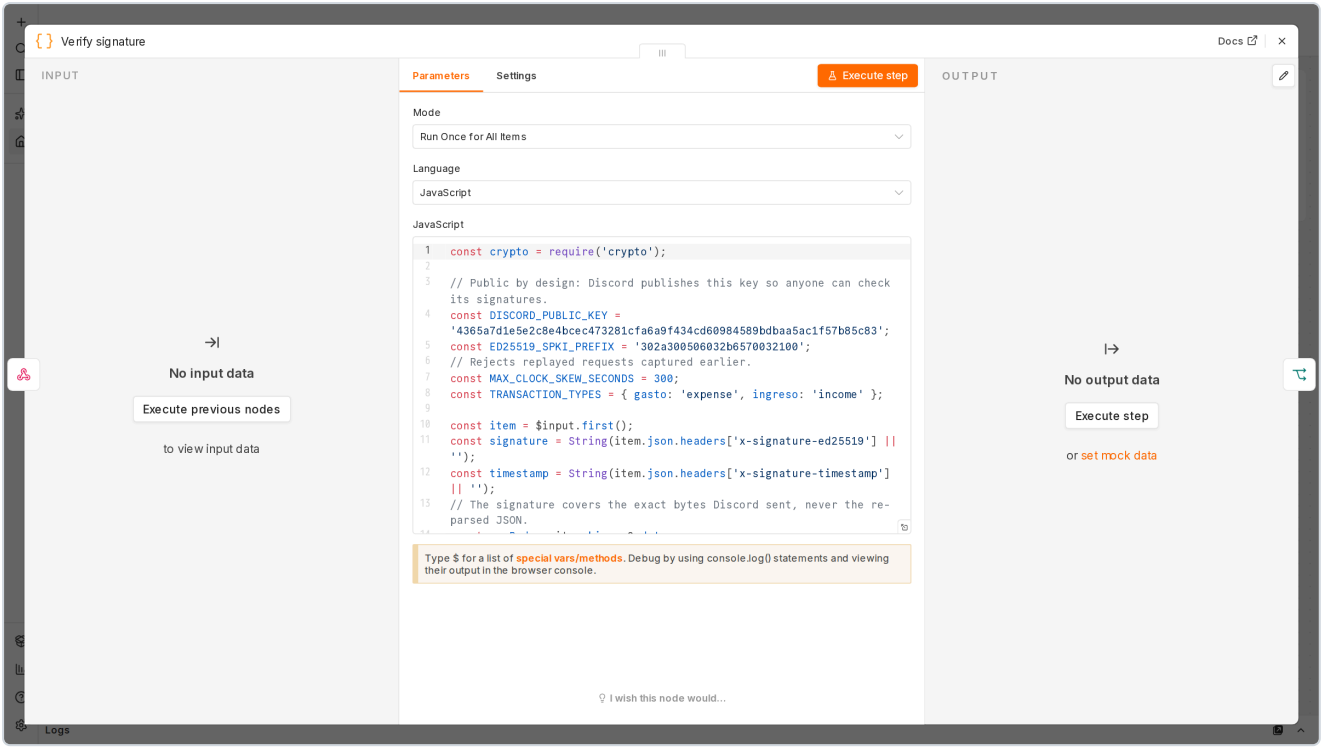
Recibe el `POST` de Discord en `/webhook/discord-interactions`. La opción **Raw Body** conserva los bytes exactos que envió Discord, que la verificación de firma necesita. Las respuestas las genera más adelante un nodo *Respond to Webhook*, de modo que la solicitud HTTP permanece abierta hasta que el bot tiene una respuesta.



2. Verify signature

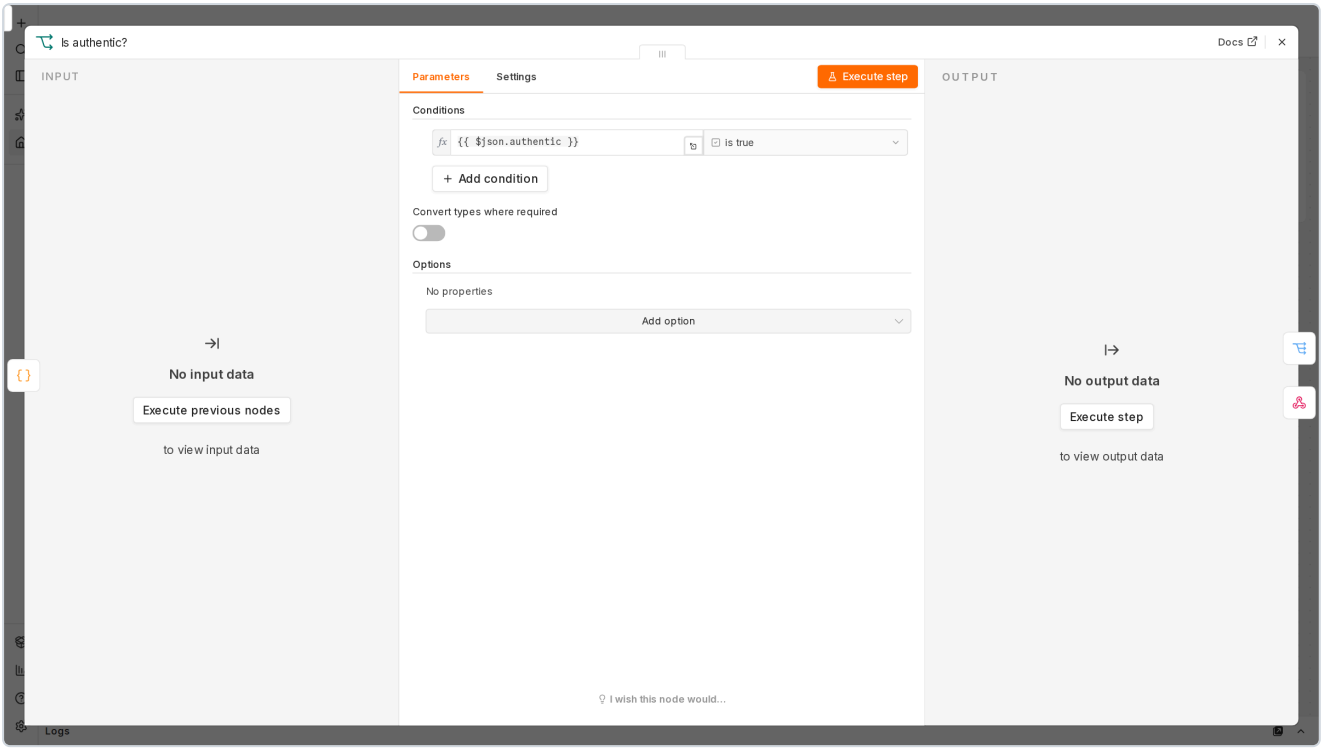
JavaScript (nodo Code). Discord firma `timestamp + raw body` con Ed25519; este nodo la verifica con la clave **pública** de Discord, rechaza timestamps con más de 5 minutos de antigüedad (solicitudes repetidas) y extrae el comando, sus opciones y el id de usuario de Discord.

Por qué los bytes sin procesar: el JSON analizado por n8n cambia valores como `1.50` a `1.5`, por lo que una verificación contra JSON re-serializado rechazaría solicitudes legítimas.



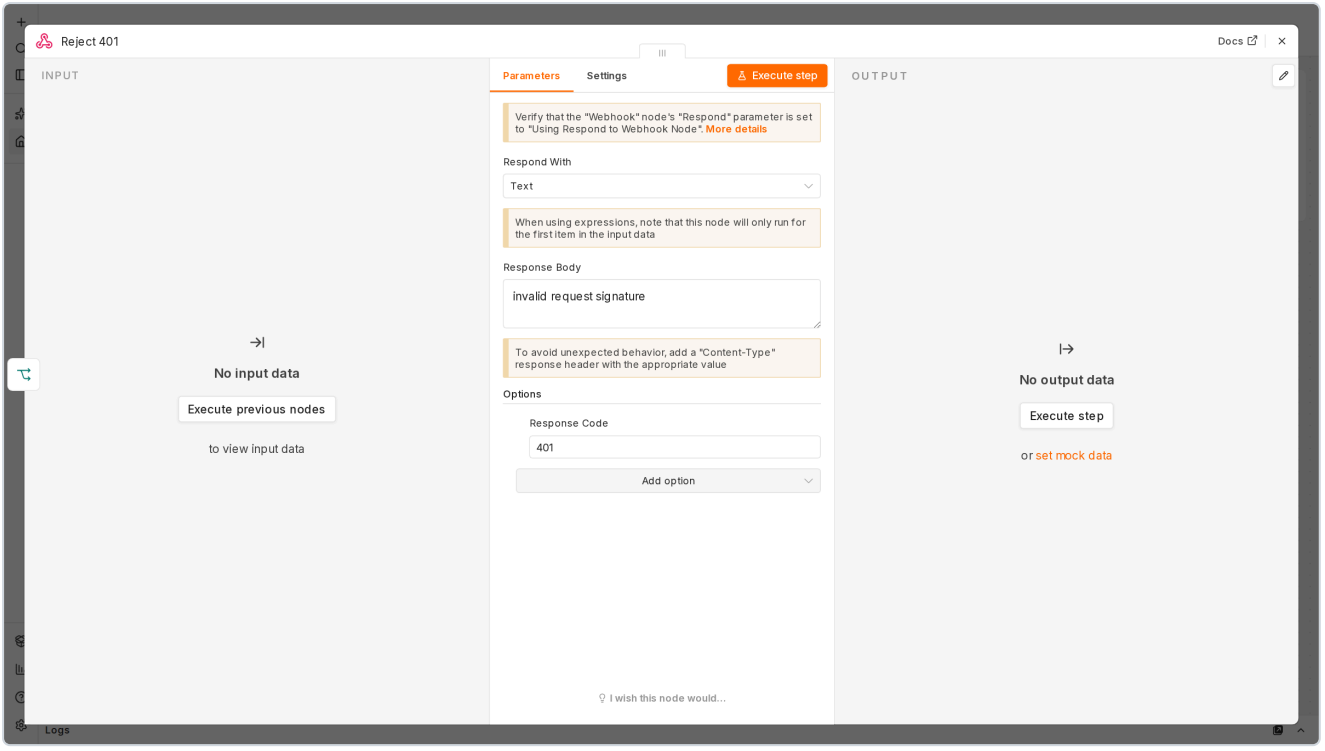
3. Is authentic?

Nodo `If` sobre el indicador `authentic`. Todo lo que no esté firmado por Discord va a *Reject 401* y nunca llega a la base de datos.



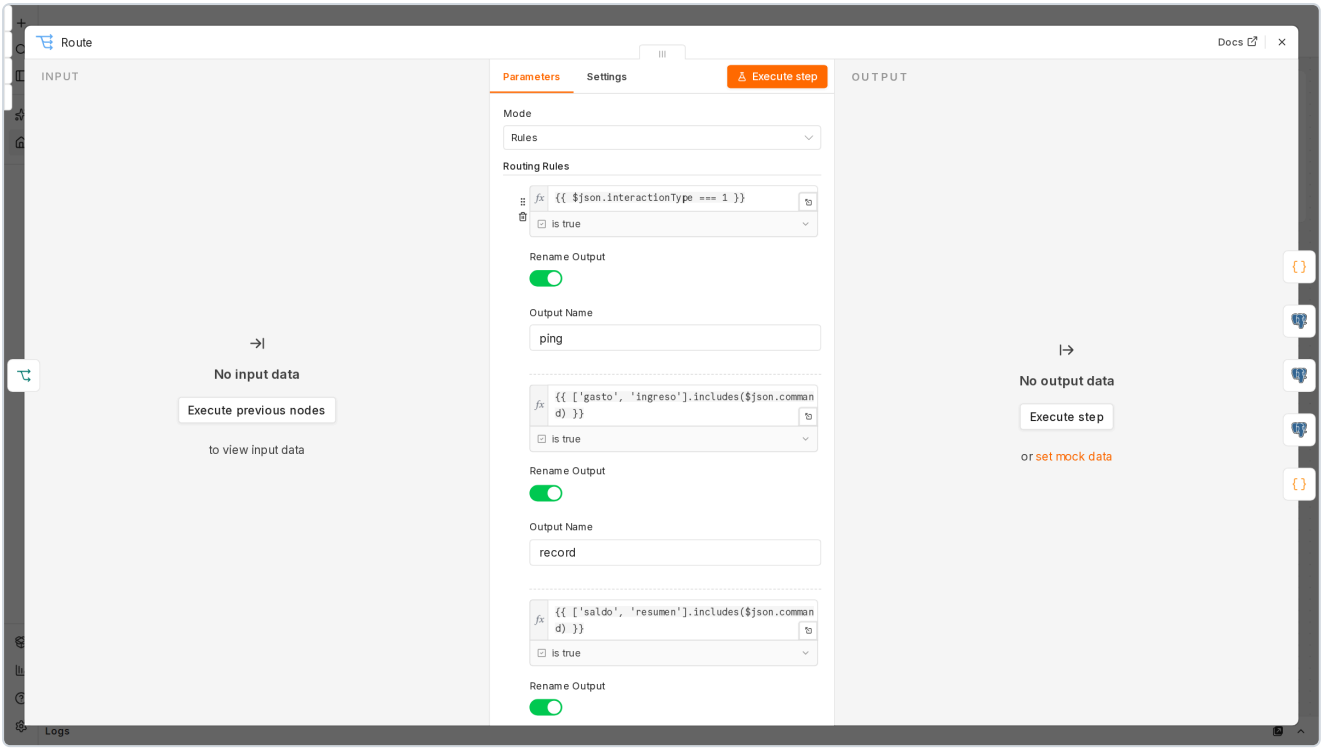
4. Reject 401

Responde `401 invalid request signature`. El propio Discord comprueba este comportamiento cuando se guarda la Interactions Endpoint URL: envía una solicitud con una firma incorrecta y rechaza la URL a menos que la respuesta sea 401.



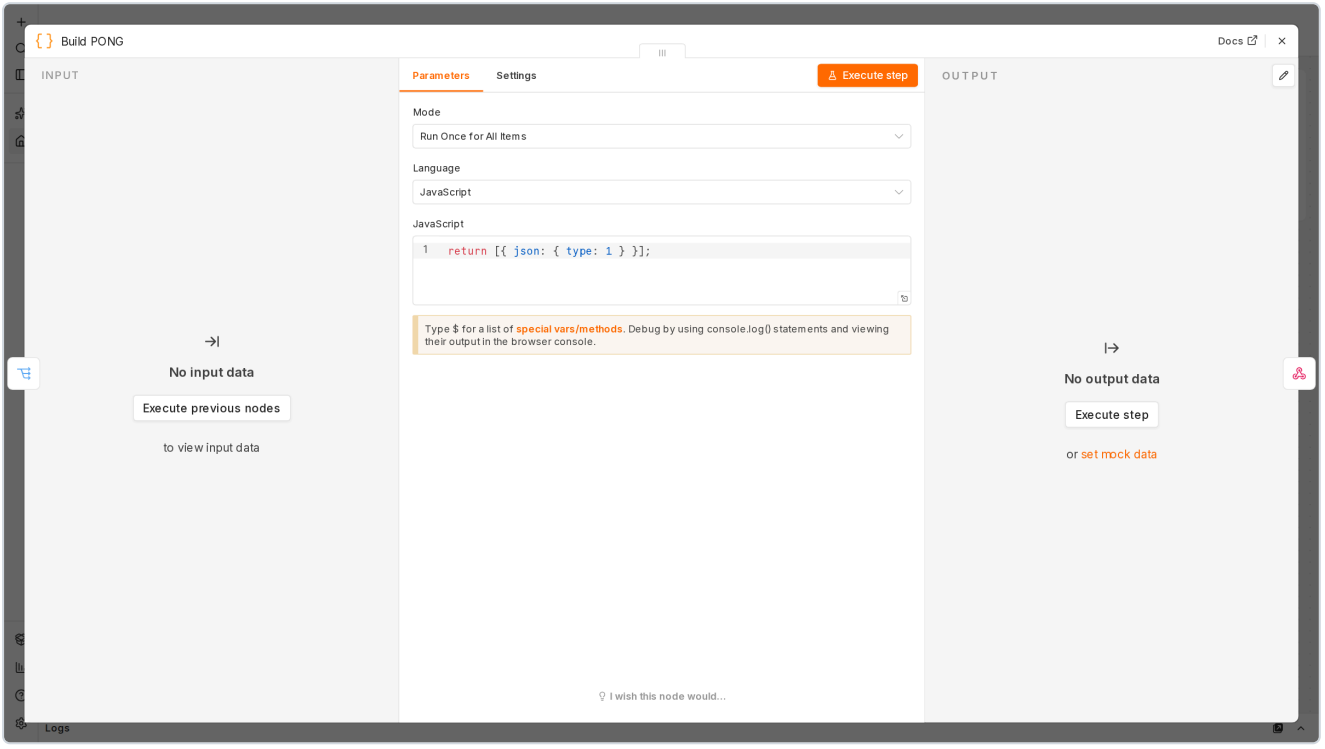
5. Route

Nodo `Switch` con cinco salidas: `ping` (la verificación de estado de Discord), `record` (`/gasto`, `/ingreso`), `summary` (`/saldo`, `/resumen`), `undo` (`/deshacer`) y `unknown` (alternativa por defecto).



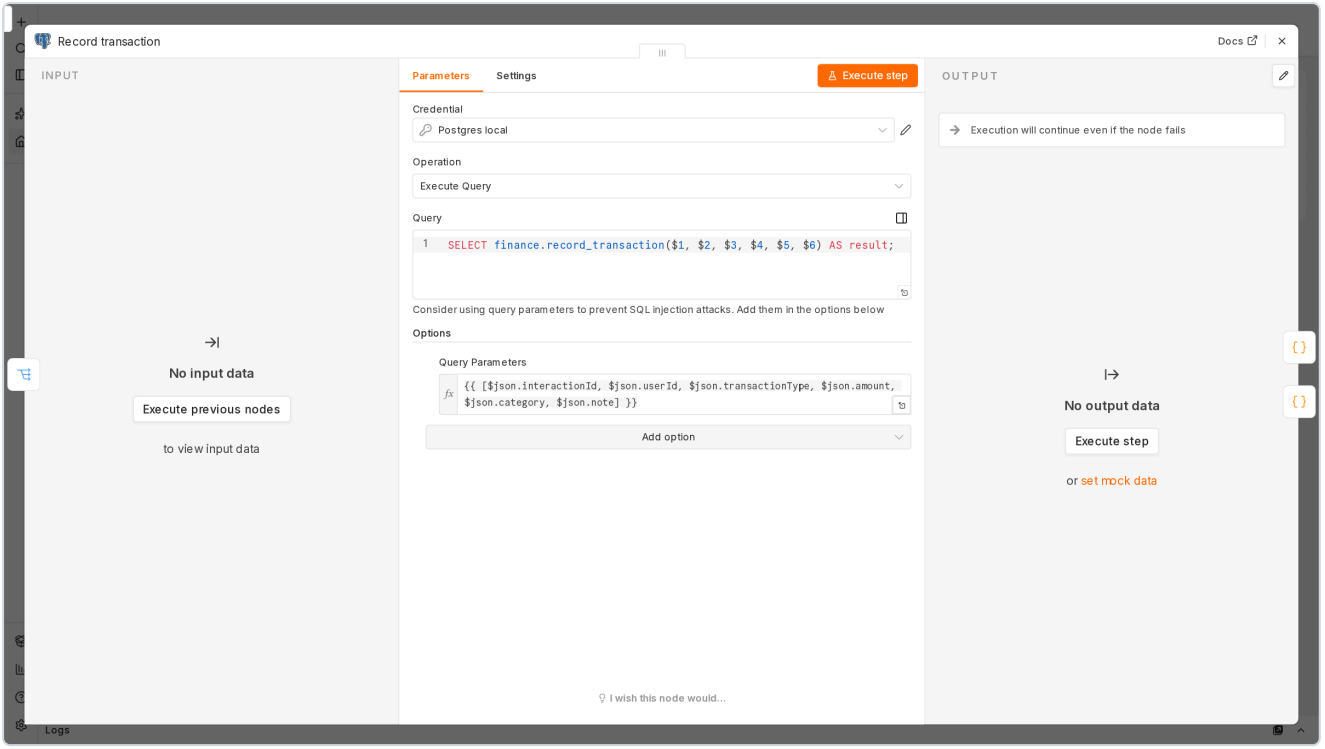
6. Build PONG

Responde al `PING` de Discord con `{"type": 1}`.



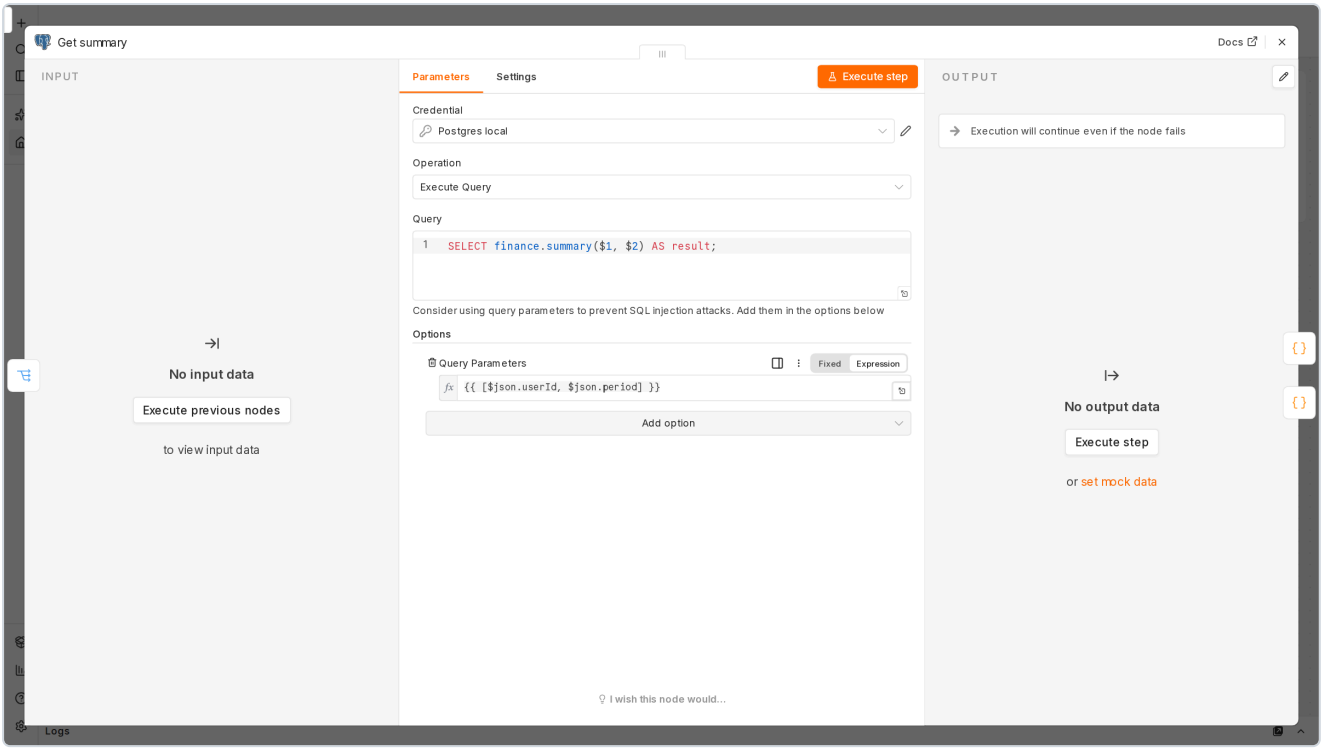
7. Record transaction

Llama a `finance.record_transaction($1, ... $6)`. Los valores viajan como **parámetros de consulta**, nunca insertados en el texto SQL, lo que descarta la inyección SQL; una nota como `arepa, tinto` se almacena con su coma intacta. La salida de error del nodo conduce a *Build database error*, de modo que una inserción fallida nunca se confirma al usuario.



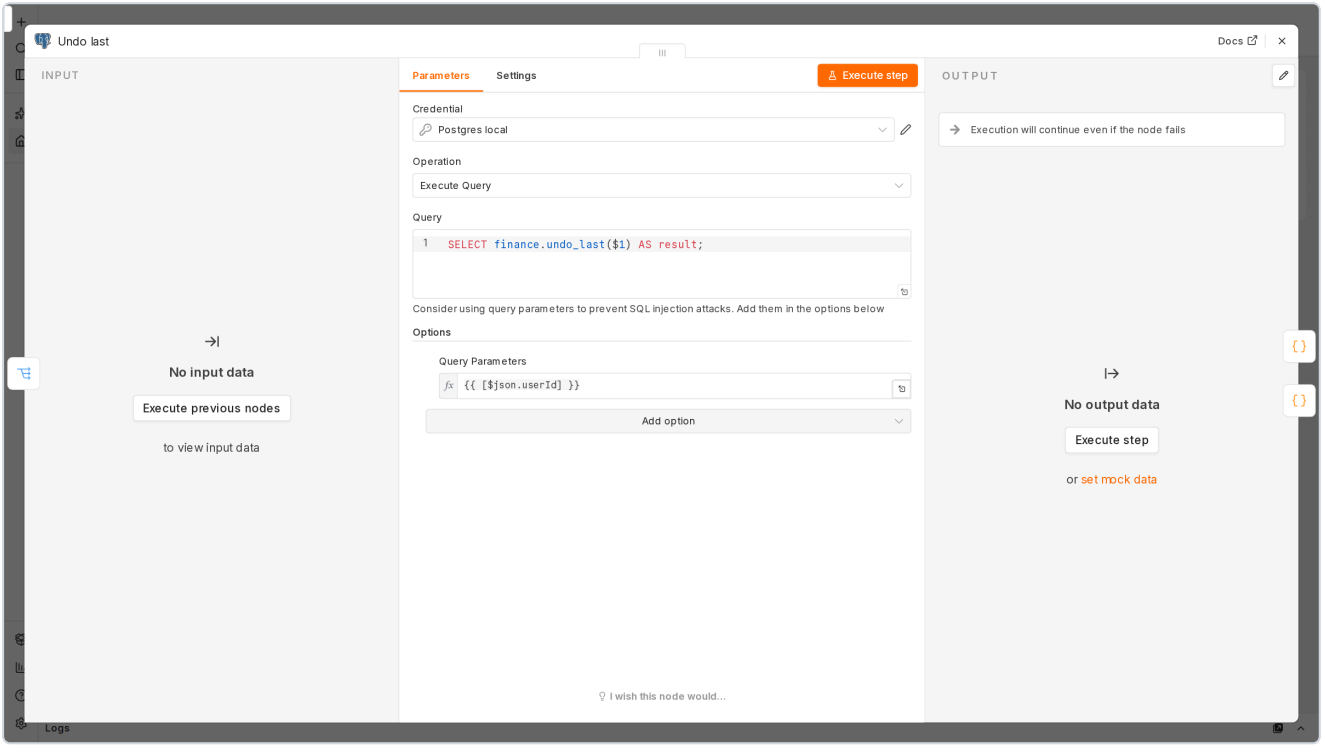
8. Get summary

Llama a `finance.summary(user, period)` para `/saldo` (mes en curso) y `/resumen` (`hoy`, `semana`, `mes`, `año`, según el calendario de Bogotá).



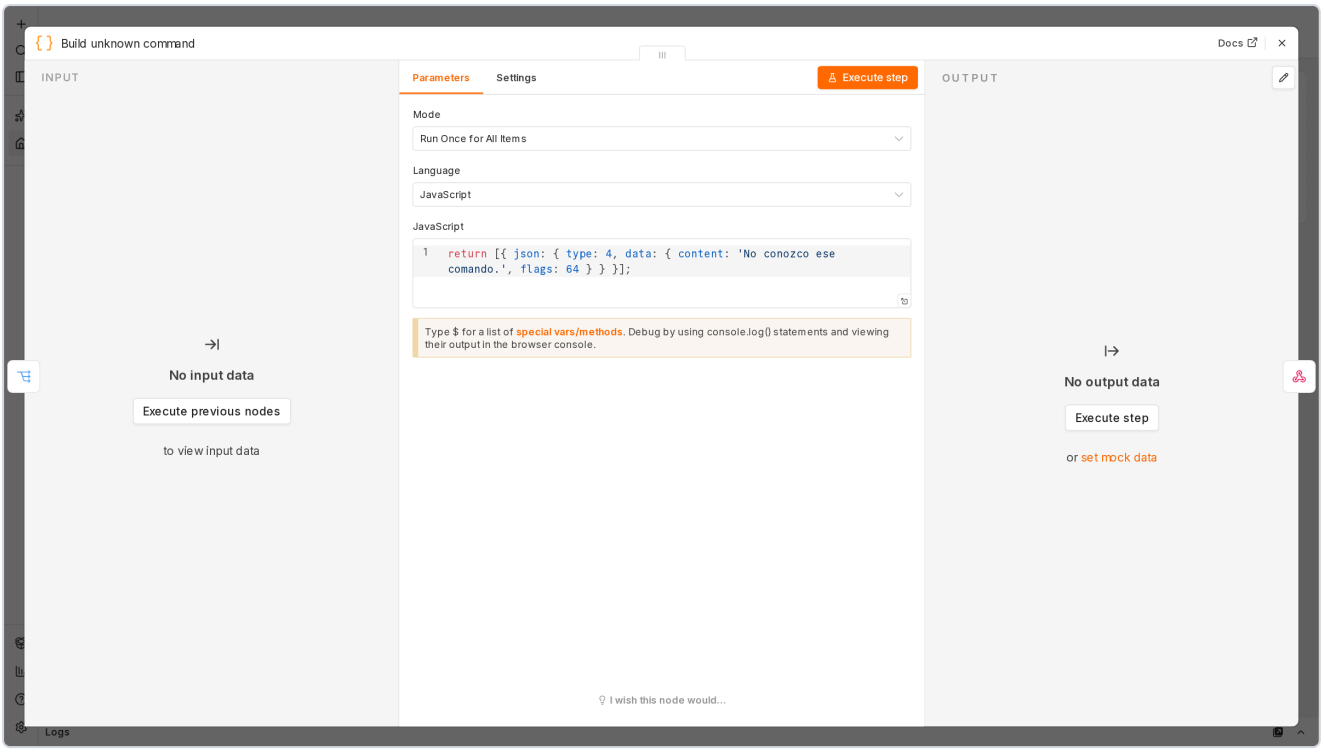
9. Undo last

Llama a `finance.undo_last(user)`, que elimina únicamente el movimiento más reciente de quien envía el comando.



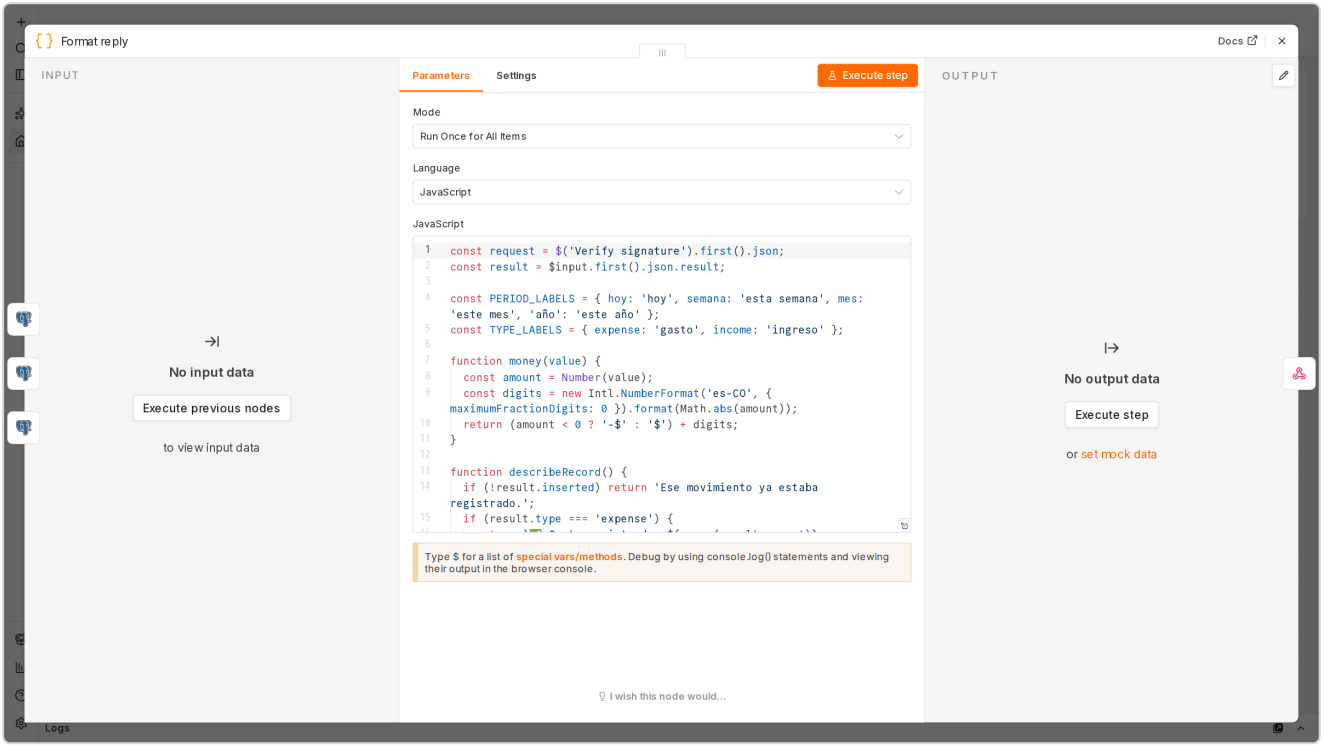
10. Build unknown command

Responde `No conozco ese comando.` para los comandos que el bot no conoce.



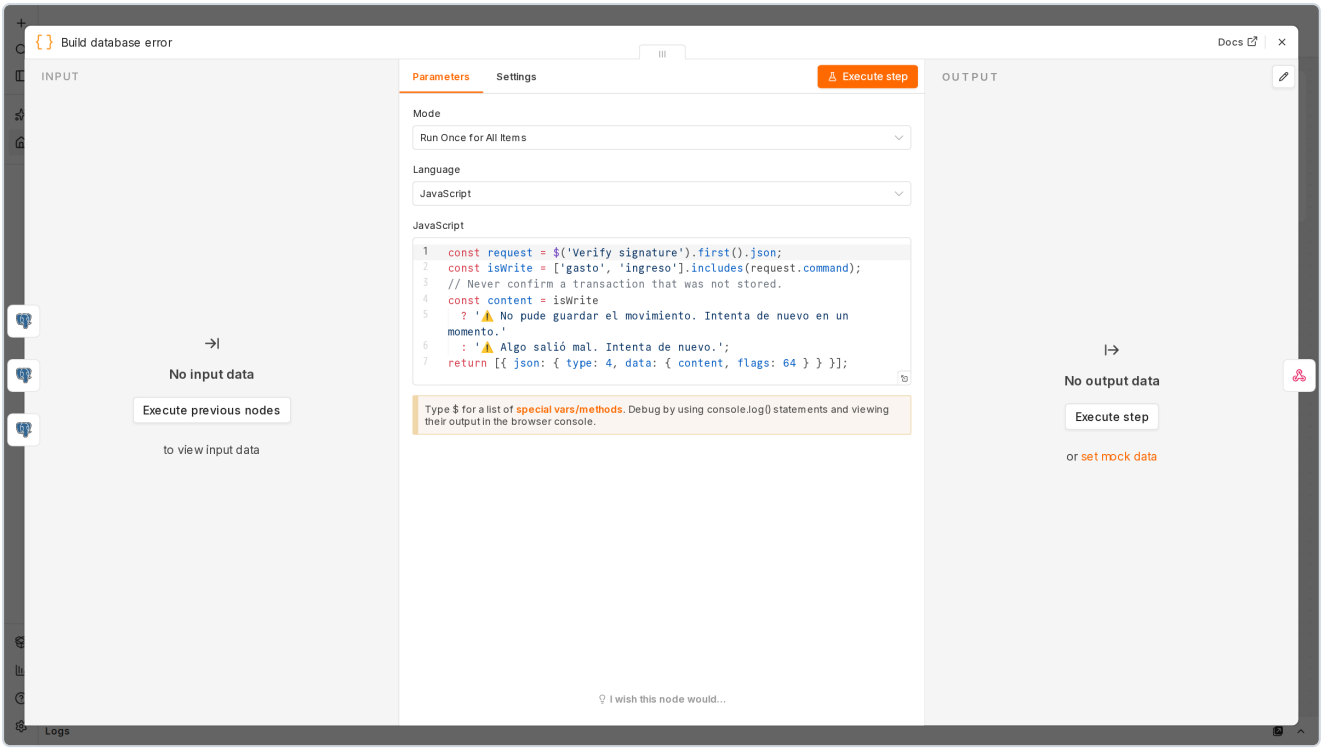
11. Format reply

Convierte el resultado SQL en los mensajes en español definidos en `docs/contract.md`, formatea el dinero como pesos colombianos (`$1.500.000`, los negativos como `-$20.000`) y establece `flags: 64` para que solo quien envía el comando vea la respuesta.



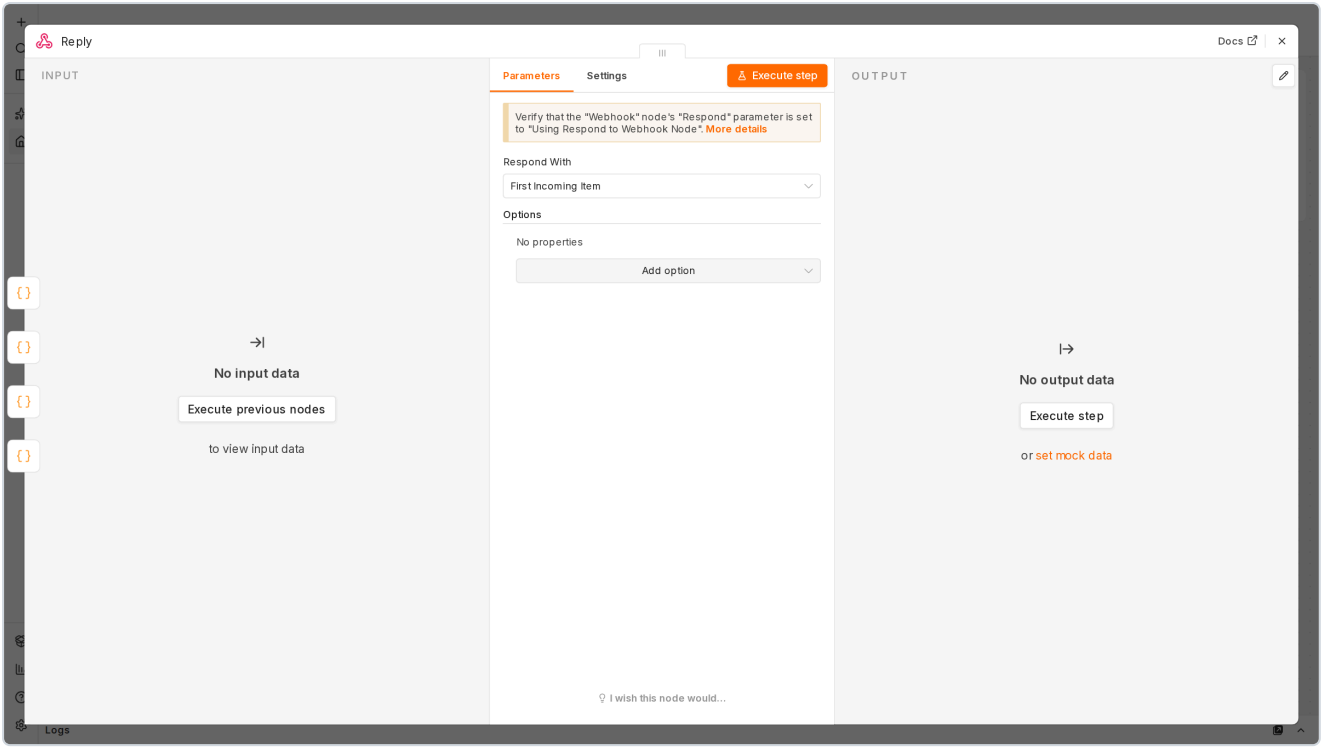
12. Build database error

Se ejecuta cuando falla un nodo de Postgres. Para `/gasto` y `/ingreso` responde `⚠️ No pude guardar el movimiento...`; en los demás casos, `⚠️ Algo salió mal...`.



13. Reply

Nodo *Respond to Webhook* que devuelve a Discord el mensaje que le haya llegado. Discord descarta las respuestas que tardan más de 3 segundos; las pruebas de extremo a extremo imponen un presupuesto de 2.5 segundos.



ADR 0001: Stack Discord + n8n + PostgreSQL

- Estado: aceptado
- Fecha: 2026-10-16

Contexto

Un bot de finanzas para uso personal debe registrar ingresos y gastos desde una aplicación de chat y responder consultas de saldo. Restricción estricta: costo cero.

Decisión

- **Canal:** slash commands de Discord, recibidos a través de la Interactions Endpoint URL.
- **Automatización:** n8n en Docker. Desarrollo local, despliegue en un Docker Space de Hugging Face.
- **Almacenamiento:** PostgreSQL. Contenedor local para desarrollo, Supabase para el despliegue. El estado propio de n8n también reside en Supabase porque el disco del Space es efímero.
- **Keep-alive:** un programador externo (cron-job.org) hace ping al Space; los Spaces gratuitos se suspenden tras 48 horas sin tráfico.
- **IA (opcional, más adelante):** modelos gratuitos de OpenRouter, solo para entradas en texto libre.

Alternativas consideradas

Opción	Por qué se descartó
Telegram	Según se informa, los Spaces de Hugging Face no pueden resolver `api.telegram.org`; el registro puede requerir pagar la verificación por SMS en algunos países
WhatsApp Cloud API	Requiere una configuración de Meta Business; demasiado pesado para una primera versión
WhatsApp mediante Evolution API	No oficial; riesgo de que se bloquee el número de teléfono
Obsidian	Archivos Markdown locales, sin una API que un bot pueda usar de forma confiable
Notion	Funciona, pero agregar montos resulta incómodo en comparación con SQL
Mensajes de texto libre en Discord	n8n no tiene un trigger oficial para ellos; requiere una conexión persistente al gateway

Consecuencias

- Positivas: gratuito, APIs oficiales, solicitudes firmadas, entrada estructurada validada por Discord.
- Negativas: los usuarios necesitan una cuenta de Discord; las respuestas deben llegar en menos de 3 segundos.

- Riesgo: las llamadas salientes desde Hugging Face hacia `discord.com` no están verificadas. Se ejecuta una prueba de conectividad antes del despliegue; los comandos básicos evitan por completo las llamadas salientes.

ADR 0002: Alojar n8n en Render en lugar de Hugging Face

- Estado: aceptado (reemplaza la parte de alojamiento del ADR 0001)
- Fecha: 2026-10-16

Contexto

El ADR 0001 planeaba ejecutar n8n en un Docker Space gratuito de Hugging Face. Al crear el Space, Hugging Face respondió: "hosting Gradio and Docker Spaces on free cpu-basic requires a PRO subscription". Desde julio de 2026, solo los Spaces creados antes conservan el plan gratuito.

Decisión

Ejecutar n8n como un servicio web gratuito de Render construido desde `deploy/Dockerfile`, en la región de Virginia (la misma región de AWS que el proyecto de Supabase). Un programador externo le hace ping para que la instancia gratuita no se suspenda.

Alternativas consideradas

Opción	Por qué no se eligió
Hugging Face PRO (~9 USD/mes)	El proyecto no debe tener ningún costo
Oracle Cloud Always Free	Requiere tarjeta; la capacidad ARM a menudo no está disponible; más trabajo de operación
Koyeb	Plan gratuito cerrado a nuevos usuarios tras su adquisición (feb. 2026)
PC del desarrollador con un túnel	El bot se detendría cada vez que el PC estuviera apagado

Mediciones (límites gratuitos de Render emulados localmente: 512 MB, 0.1 CPU)

- Memoria: 347 MB en reposo, sin terminaciones por falta de memoria.
- Arranque: unos 110 s hasta que `/healthz` responde.
- Tiempo de respuesta: de 2.0 a 4.9 s, la mitad por encima del límite de 3 s de Discord.

Mediciones en el servicio real de Render (2026-10-16)

- Ruta del webhook con verificación de firma, en caliente, 20 solicitudes desde Colombia: mediana 0.70 s, p90 0.98 s, máximo 1.28 s (unos 0.3 s corresponden a la red desde Colombia).

- Primera solicitud después de un reinicio: unos 22 s (el runner de los nodos Code se carga en el primer uso).
- `docker --cpus 0.1` resultó mucho más restrictivo que la CPU real de Render, por lo que la emulación local sobrestima los tiempos de respuesta.
- El runner de los nodos Code necesita ~47 s para arrancar, más que el grant token predeterminado de 30 s de n8n: `N8N_RUNNERS_GRANT_TOKEN_TTL=180` se establece en `deploy/Dockerfile`.

Consecuencias

- Por ahora, las respuestas síncronas caben en el límite de 3 s de Discord. Si dejan de caber, se cambiará a las respuestas diferidas de Discord (confirmar de inmediato, editar el mensaje después). La suite e2e impone un presupuesto de respuesta de 2.5 s para detectar regresiones antes de que los usuarios las vean.
- Un reinicio o despliegue deja el bot no disponible durante unos dos minutos.
- El ping de keep-alive depende de que Render lo tolere; si no lo tolera, el bot responde con retraso después de 15 minutos sin tráfico.
- El estado de n8n en producción reside en Supabase (esquema `n8n`), por lo que la instancia de Render es desechable: volver a desplegarla no pierde nada.